

Collaborative Cybersecurity Framework for CNS

Valerio Senni
Collins Aerospace
Rome, Italy

Valerio.Senni@Collins.com

Davide Martintoni
Collins Aerospace
Trento, Italy

Davide.Martintoni@Collins.com

Laurent Leonardon
Collins Aerospace
Toulouse, France

Laurent.Leonardon@Collins.com

Timo Warns
Airbus Operations GmbH
Hamburg, Germany
Timo.Warns@Airbus.com

Cristian Bertoldi
Airbus Operations SAS
Toulouse, France
Cristian.Bertoldi@Airbus.com

Abstract—The ever-evolving cybersecurity threat landscape and an increasing threat exposure require a transition to overarching and harmonized security approaches for future Communication, Navigation, and Surveillance (CNS) systems. Such approaches are essential for end-to-end and interoperable security measures being prerequisites for the protection of aviation's digital infrastructures. While CNS stakeholders have in place different cybersecurity risk management processes and mitigation practices, they often run independently from each other with limited coordination. This paper presents a cybersecurity framework, under development within the Future Communications Digital Infrastructure (FCDI) project of the SESAR JU program, to support CNS stakeholders in collaboratively identifying cybersecurity threats, defining an end-to-end cybersecurity posture, and refining the identified threats and security objectives per stakeholder scope of responsibility. By the proposed framework, collaborative threat elicitation, which is based on well-established threat modeling methodologies, yields a threat model serving as a cross-stakeholder coordinating artifact as well as an input for supporting each stakeholder's cybersecurity process. Similarly, mitigation is driven by a collaborative approach, fostering the adoption of Zero Trust principles within and across stakeholders' scope of responsibilities.

Index Terms—collaborative cybersecurity, threat modeling, zero trust, threats mitigation, integrated CNS

I. INTRODUCTION

The connectivity and integration of civil aviation air and ground systems is increasing, supporting the future Air Traffic Management (ATM) optimization needs [1]. Future Communication, Navigation, and Surveillance (CNS) systems will be core enablers of this digital revolution, establishing interdependencies and information flows between previously separate services and infrastructures. Alongside, the risks resulting from the ever-evolving cybersecurity threat landscape with an increasing potential for threat propagation between systems will draw currently isolated security approaches insufficient. To ensure interoperable solutions without gaps in protection, cybersecurity threats to CNS systems can no longer be addressed independently for aircraft and ground. As such, CNS stakeholders need support in collaboratively establishing and maintaining an adequate cybersecurity posture.

This research is funded by the European Union's SESAR Joint Undertaking program FCDI under grant No. 101114729.

Supporting the collaboration on cybersecurity is a prerequisite of (1) ensuring the enforcement of security policies for an end-to-end protection of safety- and operation-critical functions, (2) reducing margins for advanced threats to exploit unknown gaps in system and integration security architectures, (3) moving from an "implicit and static trust" and "perimeter based" cybersecurity approach to an "explicit and dynamic trust" and "per interaction" approach, by involving all relevant stakeholders in the implementation of threat mitigation actions across the CNS infrastructure, and (4) clarifying the role and responsibility of each stakeholder.

There are several challenges to address for an effective cybersecurity collaboration, in particular a lack of: (1) adequate methods and tools to track assets, threats, and related equipment to facilitate collaboration of all the involved parties, (2) frameworks to overcome diversity across domains in cybersecurity standardization, (3) solution concepts to promote interoperability of the security infrastructure of different stakeholders to enable comprehensive visibility and response, and (4) processes to facilitate cybersecurity information-sharing between stakeholders, while minimizing unneeded disclosures of intellectual property or other sensitive information.

This paper provides an overview of the work in progress in the Work Package 2 of the SESAR FCDI project [2] for the definition of a Collaborative Cybersecurity Framework for CNS addressing the challenges described above and ensuring adequate security protections for future CNS systems. Its intent is to raise awareness and collect feedback from the CNS community for improving the value proposition and promoting the adoption of the proposed framework.

The Collaborative Cybersecurity Framework fosters an end-to-end protection of CNS/ATM *information flows*, *data*, and *service* assets, while leaving more detailed protection considerations for each domain at the discretion of the responsible stakeholder. It aims at supporting stakeholders in the early identification of threats and in the definition of the overall cybersecurity posture. The framework is composed of two main elements:

- a methodology for Collaborative Threat Modeling, and
- a Reference Zero Trust Architecture.

The *Collaborative Threat Modeling* aims at supporting CNS stakeholders in the definition of joint security objectives and in the coordination, towards those joint objectives, of heterogeneous Cybersecurity Risk Management processes adopted in different domains. The proposed approach defines a common and simple language for cybersecurity information-sharing, by representing assets, information-flows, trust relations, realms of responsibility, entities with different security capabilities, links between architectural elements, assets, and threat categories.

The *Reference Zero Trust Architecture* provides architectural templates, which can be used as guidelines for threat mitigation considerations across or within domains. It standardizes key enabling components as well as their interfaces facilitating interoperability. Promoting the adoption of Zero Trust principles [3], it aims to make explicit what is typically implicit trust, to ensure that all the required conditions are in place to grant trust, and to support the definition of baseline security building blocks along with their requirements.

The proposed framework is not in competition with and does not aim at replacing any existing Cybersecurity Risk Assessment processes and methods. Providing inputs to these processes, it rather supports coordination between stakeholders in the heterogeneous CNS ecosystem. For example, the Framework is aligned and can be integrated with the SecRAM [4] method as used by SESAR JU projects. This includes the (1) reuse of established concepts such as Primary Assets, Security Properties, Supporting Assets, and Catalogues, (2) coordination of multiple SecRAM executions by providing harmonized inputs, with more accurate documentation of end-to-end information flows mapped to assets, and (3) facilitation of collaborative mitigation strategies, while risk evaluation and overall management remains in the scope of SecRAM or other cyber risk management methods. Moreover, the Framework adopts and consistently follows STRIDE [5] concepts for threats elicitation. STRIDE is well-recognized as a simple, yet effective, method for threat elicitation, but other approaches are possible, such as choosing sector-specific catalogs, as long as the same abstraction level is maintained across the Framework application.

While still under development, the Framework already achieves a number of useful results at the current maturity level, including: (1) establishing a minimal amount of knowledge needed for stakeholder collaboration, (2) providing concrete methods to represent cybersecurity-relevant knowledge, (3) facilitating standardization of equipment cybersecurity features across heterogeneous domains by means of Security Profiles, and (4) supporting the application of Zero Trust principles on cross-stakeholders security integration scenarios from Communication and Surveillance domains.

II. CYBER-SECURITY CHALLENGES FOR FUTURE CNS

The Collaborative Cybersecurity Framework is motivated by different challenges for the cybersecurity of future Communication, Navigation, and Surveillance (CNS) systems, including

an evolving threat landscape, an increasing threat exposure, inconsistent security approaches, and imprecise approximations on the level of trust and security.

The threat landscape that a system is facing is not static, but under continuous evolution. For example, new types of threats may be discovered introducing new threat scenarios and security risks. Likewise, threats that were considered on a theoretical basis may materialize in-service increasing security risk levels. The evolution of the GNSS jamming and spoofing threat over the last couple of years [6] has strikingly illustrated that future CNS systems are not exempted from such evolutions, but require an adequate security risk management.

Future CNS systems increasingly rely on technologies associated with a threat exposure different from the one of legacy systems. For example, new communication infrastructures like ATN/IPS, LDACS, and Hyper-Connected ATM introduce the Internet Protocol to safety communication [1] and, while bringing many benefits, need to be protected against security threats that are not applicable to legacy means, but are widespread in the standard IT world. Similarly, introducing standard technology to ground-ground CNS infrastructure requires careful considerations on the resulting security risks and required protections.

Despite these needs, no harmonized approach on addressing security across CNS systems and stakeholders has materialized yet. For example, for some future CNS systems (like ATN/IPS, Hyper-Connected ATM, or LDACS), security is a first-class stake considered from the beginning of their definition. However, given the lack of an established security framework, different approaches have been taken in different contexts. For other systems facing threats in-service (like GNSS), standards are under revision closing gaps of protection. Again, given the lack of an overall framework, the underlying approach is not harmonized and may not yield protections as efficient and comprehensive as possible. For some established CNS systems that are less subject to threats in-service, dedicated baseline security protections remain a secondary stake.

While different CNS stakeholders manage the security risks for their scope of responsibility (e.g., to satisfy regulatory needs), they generally apply different approaches with limited coordination with other CNS stakeholders. For example, EUROCAE ED-202B [7] and ED-203A [8] describe the processes and methods for airworthiness security to be applied for the certification of aircraft and aircraft systems. Similarly, ED-205A [9] describes such a process for the certification and declaration of ground ATM/ANS systems. However, these standards hardly provide guidance when and how to coordinate system, trust, and threat models across stakeholders.

While the EUROCAE ED-20x security document series provides guidance and methods on how to assess the security risks of threat scenarios for a security scope, they often are applied with imprecise approximations for system, trust, and threat models. On the one hand, trust assumptions are considered binary relations: Either an entity is trusted or not trusted and, thereby, excluded from further risk considerations

or not. However, in a collaborative security approach, more fine-grained trust assumptions can better support the definition of an overall security posture: Trusting an entity for certain interactions, while not for others, supports the definition of security measures specifically tailored to risk mitigation needs. On the other hand, system, trust models treat all entities of the same type equally: The same trust assumptions and the same threats apply to all entities of the same type, even if they are subject to different security levels. Consequently, an entity with the lowest level of security often drives the trust and threat model considered by a stakeholder.

Overall, the challenges described above may yield unnecessary security protections (e.g., due to stakeholders developing protections against threats that are already mitigated by other stakeholders) or gaps in protection (e.g., due to unjustified trust assumptions). A robust and collaborative approach with fine-granular trust models and harmonized priorities will reduce over-engineering, close protection gaps, and establish a unified cybersecurity posture, ensuring resilience for both current and future CNS systems.

III. COLLABORATIVE THREAT MODELING

Collaborative Threat Modeling has the objective of supporting cross-stakeholder coordination on the threats that need to be addressed, the definition of security objectives, and mitigation decisions. As illustrated by Fig. 1, it is split into two layers. The upper layer (A) covers the *Global Threat Modeling*, an activity collaboratively performed by all relevant stakeholders at an adequate level of abstraction. The associated activities are further described below. The lower layer (B) covers the *Local Security Activities* independently performed by each stakeholder according to their own processes and needs (e.g., to meet regulatory requirements).

The proposed framework is not meant to replace existing cybersecurity risk assessment methods, but provides inputs to their processes. In particular, the Global Threat Modelling yields *slices* of the global threat model for each stakeholder as input for the Local Security Activities, which are expected to further refine the threat model slices and continue at a higher level of technical detail. The integration with existing cybersecurity risk management methods is further discussed below.

The Global Threat Modelling is structured into four main steps. First, Shared Security Objectives are defined requiring an identification of the Primary Assets (PAs) [4] (services or data) selected by stakeholders for protection. Security Objectives are expressed in terms of the desired security properties for each PA. There are different approaches that can be adopted for the selection of Security Properties: a frequently adopted practice is to rely on the Confidentiality, Integrity, and Availability triad (CIA), while in the current work an extended set of Security Properties is considered. Second, a Joint Threat Model is developed, representing the integration architecture, trust boundaries, and elicited cross-stakeholder threats. The architecture modeling is based on Supporting Assets (SAs) [4] and their communication links by means of Data

Flow Diagrams (DFDs). Trust boundaries are used to identify potential sources of threats. Threats themselves are identified by means of a systematic analysis of the Threat Model against a set of threats of interest. Third, collaborative mitigation actions are discussed and decided by the stakeholders for critical threats. Mitigation is likely going to change the Joint Threat Model, for example by additions of SAs implementing security measures, or by removals of trust boundaries due to the positive effects of identified mitigations, causing an increase of trust in some parts of the defined architecture. Mitigation generates Security Requirements that have to be satisfied by the actual equipment playing the role of a specific SA. Security requirements can be grouped and standardized by the definition of Security Profiles, that identify equipment classes and guidelines for qualification. As the fourth and final step, slicing and harmonization address the need for interfacing the Global Threat Modeling activity with the Local Security Activities performed by each stakeholder. They support the identification of responsibilities and propagation of security requirements to each stakeholder. They are also in charge of keeping consistency between Local Security Activities and the Global Threat Modeling.

In the following, each of these four steps is discussed in more detail and illustrated by examples.

A. Primary Assets and Shared Security Objectives

Primary Assets (PAs) are a well known concept from Security Risk Assessment methods and, specifically, from SecRAM [4]: *"They are intangible activities, information and services that are of value and need to be protected. A successful attack would ultimately impair the primary assets and have an impact on the ATM system."* SecRAM is recommended to be applied at *"service-level"* and, as such, PAs are primarily of two types: service and information. In order to support harmonization across diverse ATM domains, SecRAM promotes the use of catalogues for a number of key concepts, including PAs.

SecRAM considers three standard security properties of PAs to be evaluated to assess the impact of a cybersecurity threats: Confidentiality, Integrity and Availability. The current proposal, in compliance with STRIDE [5], considers an extended set of properties as shown in Table I.

TABLE I: STRIDE Security Properties and Threat Categories

Security Property	STRIDE Threat
Authentication	Spoofing
Integrity	Tampering
Non-Repudiation	Repudiation
Confidentiality	Information disclosure
Availability	Denial of service
Authorization	Elevation of privileges

B. Joint Threat Model

Creating a threat model for a system requires a representation of the system itself, i.e., a system model. While numerous

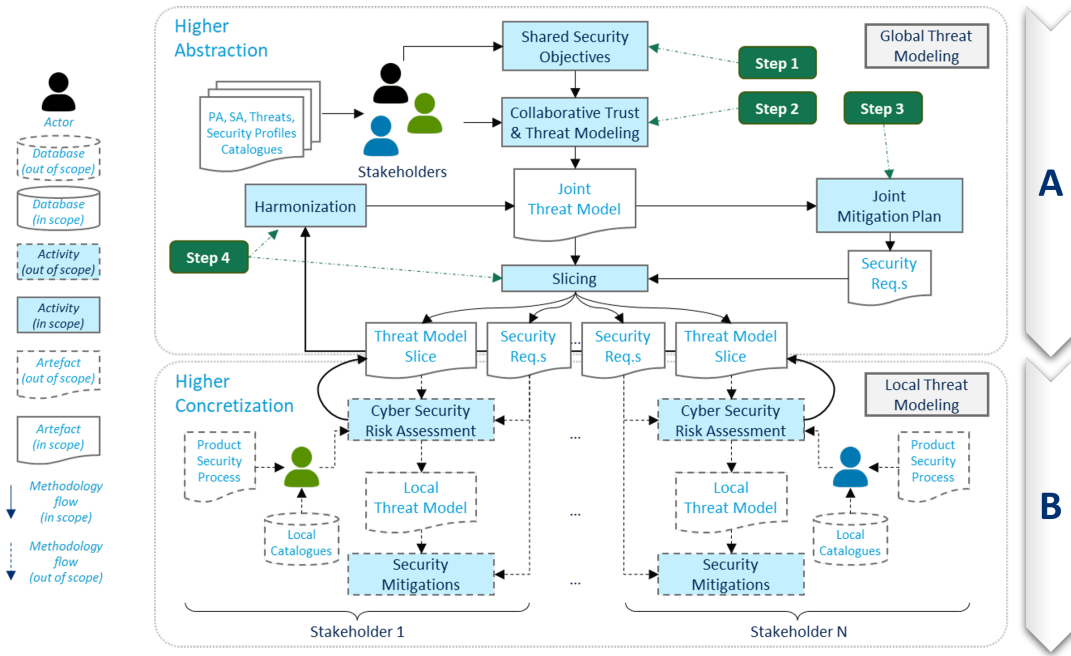


Fig. 1: Collaborative Threat Modeling Flows

approaches for system modeling are available, the approach proposed in this document is to represent a system in terms of its entities and the data flows between its entities. This approach is not particularly new, but follows widely used threat modeling approaches such as the STRIDE method [5] (with minor adaptations). In more detail, a system is assumed to be modeled by a directed graph with the graph's nodes representing the system's entities and (directed) edges representing the system's data flows.

An entity may be internal (part of the system itself) or external (part to the system environment) and corresponds to a Supporting Asset (SA) as per the definition in SecRAM [4]. Three types of entities are distinguished: internal processes, internal databases, and external inputs/outputs. Each entity and data flow is assumed to have associated a unique identifier. A system model may be graphically represented by a Data Flow Diagram (DFD) with a graphical notation as illustrated in Fig. 2.

A *process* (see Fig. 2a) is an internal entity that processes data. It may receive data from another entity (represented by a data flow incoming to the process) and may provide data to other entities (represented by a data flow outgoing from the process). A *data store* (see Fig. 2b) is an internal entity that stores data. It may receive data to store from another entity (represented by a data flow incoming to the data store) and may provide stored data to other entities (represented by a data flow outgoing from the data store). It is graphically represented by two parallel, horizontal lines with the identifier of the data store between them. An *input/output* (see Fig. 2c) is an external entity that may provide data to the system (represented by a data flow from the input/output to a system

process or data store) or may consume data from the system (represented by a data flow from a system process or data store to the input/output). If the precise type of an entity (process, data store, input/output) is not of relevance in a graphical representation, the entity (internal or external) can be graphically represented by a rounded rectangle with the identifier of the entity inside (see Fig. 2d). A *data flow edge* models a transfer of data from the edge's source entity to the edge's target entity (see Fig. 2f).

An entity may comply with a *security profile* (further explained below), which is represented as an attribute or label of the entity (see Fig. 2e).

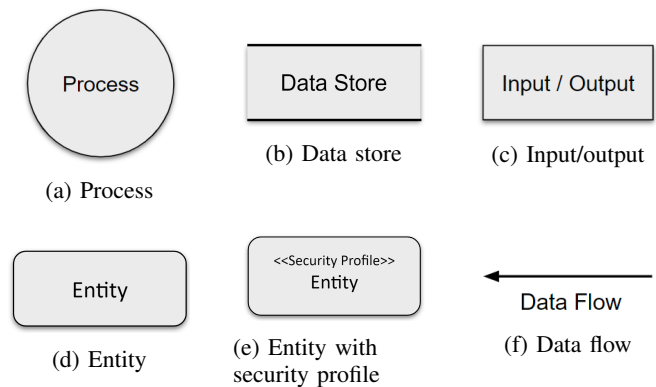


Fig. 2: Data Flow Diagram notation

In addition to the system model, creating a threat model requires a trust model expressing the trust relations among entities. Intuitively, a trust relation between an entity A and an entity B expresses that A “trusts” B in the sense that

no threats have to be considered with respect to the data flows from B to A in further threat elicitation steps. Trust relations are represented by trust boundaries at data flow level. A trust boundary is graphically represented by a dashed red line traversing the data flow to which the trust boundary is associated (see Fig. 3a). A trust boundary expresses a negative trust relation (i.e., “distrust”): a trust boundary crossing a data flow from entity B to entity A expresses that A does not trust B with respect to the specific data flow. This implies that, in threat elicitation, threats shall be evaluated for that data flow. Like for the system model, this approach is not particularly new, but follows widely used threat modeling approaches such as the STRIDE method (with some minor adaptations).

A dashed red line cutting multiple data flows represents several trust relations. For example, Fig. 3b illustrates mutual distrust between A and B. On the contrary, Fig. 3c represents a sensitive entity that shall be protected from the untrusted entity, not vice versa: only the data flow from the untrusted entity to the sensitive entity can be associated with a trust boundary.

To enable fine-grained trust models, a trust boundary may additionally be associated with conditions on the trust relation (represented by a note as in Fig. 3a). Such a condition is a statement in terms of entity attributes (e.g., regarding the security profile of an entity), the current system state, and threats to consider. For example, such conditions allow to express a negative trust relation in case of (1) an entity not complying with a particular security profile, (2) the system being in a specific state/phase, or (3) specific threats to consider/disregard (e.g., spoofing, but not tampering).

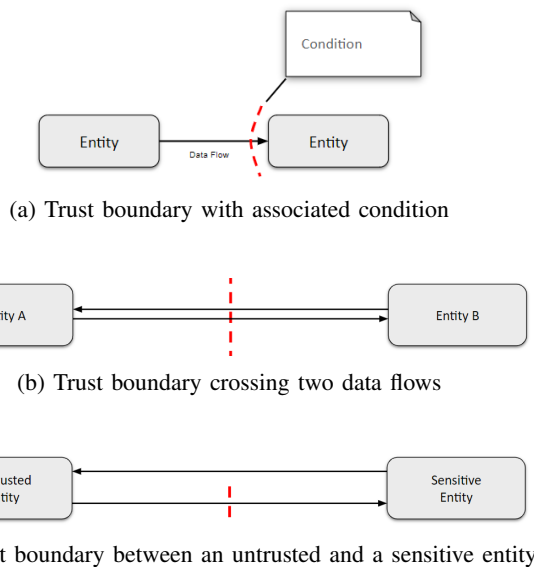


Fig. 3: Trust boundary notation

By the SecRAM method, every PA is mapped to one or more SAs implementing the PA. As impacts are considered in terms of PAs, these mappings support the impact evaluation of threats, which apply to SAs. A PA can be mapped to different sets of SAs depending on the information flows and services

infrastructure considered. This provides greater accuracy on elicitation and mitigation of threats for a specific PA, while supporting the reduction of cybersecurity over-engineering.

For illustration, Fig. 4 shows a notional and simplified example of a system and trust model for a data collection, analytics, and reporting context offered to external customers. The Primary Asset is “Data Analytics”, to be protected in terms of integrity and confidentiality. The information flow starts from information collected from input A, goes through elaboration in Process B, and terminates in a report stored in storage C, while a Process D can request access to stored reports. The figure represents that A, B, and C are in a common trusted domain (Data Analytics Service Provider) and flows traversing a Trust Boundary: (1) D is an external and untrusted entity accessing the data, (2) some parts of the analytics infrastructure (abstractly shown by a red triangle) are untrusted and have direct flows to the processing node B, and (3) storage node C has outgoing flows that feed other parts of the infrastructure (abstractly shown by a red triangle) that are untrusted, such as cloud-based backup solutions. Blue elements of the figure are for illustration purposes (and not formally part of the DFD): (1) the thick blue arrow and related “PA-01 Data analytics” shows the overall information flow, (2) Information is represented in its three possible states, “in transit”, “in use”, and “at rest”, and (3) a Service is shown in execution at Process B.

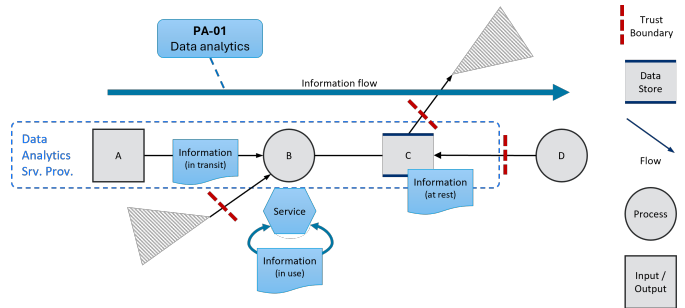


Fig. 4: Exemplary Data Flow Diagram

An example of an information flow driven mapping from PAs to SAs is given in Tab. II showing the mapping of a “Data” PA to a data flow (DF1) involving six SAs. Each involved SA is owned by a specific stakeholder (e.g., aircraft, data provider, service provider, ATC/AOC end user) and located in a corresponding domain. The knowledge that an information flow traverses multiple domains is relevant for threat elicitation, as discussed below.

C. Security Profiles

As part of the contribution of the Framework to collaboration, a notion of Security Profiles is introduced with the intent of standardizing cybersecurity capabilities and assurance means across the heterogeneous ecosystem of the integrated CNS architecture.

A Security Profile is a statement of security objectives for an equipment and serves as a “contract” between parties.

TABLE II: Information flow driven mapping from PAs to SAs

Primary Asset	Supporting Asset	Data flow	Domain
Data	SA-12 Data source	DF1.1	A/C
	SA-04 Data collection service	DF1.2	DATA PRV
	SA-25 Data analytics service	DF1.3	SRV PRV
	SA-06 Service gateway	DF1.4	SRV PRV
	SA-11 Service front-end	DF1.5	SRV PRV
	SA-01 User interface	DF1.6	ATC/AOC

One party can establish trust on another party on the basis of compliance with a specific profile (adequate to justify the trust relation). As such, a profile acts as a validation artifact for the trust relation. Similar to Common Criteria Protection Profiles [10], a Security Profile is described in terms of functional and assurance requirements. In addition to providing assurance at design and integration time, a Security Profile can support dynamic security measures and foster Zero Trust principles. In particular, during operations, it can support differentiating between entities of the same type but with different levels of trust, because of their compliance with different security profiles. Finally, Security Profiles play a role in threat modeling. In particular, they can influence Threat Elicitation, by suppressing selected threats or providing conditions for them to apply, and influence use and meaning of Trust Boundaries, particularly when used for clarifying conditions for trust.

The following sections provide more details and some examples of Security Profiles and their role.

D. Threat Elicitation and Joint Mitigation

Threat Elicitation is driven by Primary Assets and their mapping to Supporting Assets, on the basis of an established information flow. The analysis of each information flow shall consider both, services and information (in transit, at rest, or in use), per each flow. STRIDE threat categories can be adopted for evaluating each element of the information flow. STRIDE envisions application in two possible approaches: *per-Element* and *per-Interaction*. The first would lead to the evaluation against STRIDE categories of every Supporting Asset, also considering the incoming and outgoing flows. The second would lead to the evaluation against STRIDE categories of every interaction entity-flow-entity in the selected information flow. It is not clear whether one or the other is preferable and in which scenarios it delivers best results. For demonstration purposes, the current section adopts the *per-Interaction* approach, while leaving to the reader to take the most appropriate option for a specific application domain.

In the “Data Analytics” example above, threats to C from the interaction with D are considered: someone may try to impersonate D, or interfaces exposed to the untrusted domain where D is located may be attacked. In both cases, information stored in C may be compromised or leaked. Similarly, in the flow that allows C to transfer data to untrusted entities, data may be subject to disclosure to unintended parties. Finally, flows to B from other parts to the infrastructures may

compromise integrity of the analytics report or feed corrupt data. Trust Boundaries support focusing the STRIDE analysis on sensitive flows and eliciting threats with impacts on Primary Assets.

When applying the “per-Interaction” Threat Elicitation, a template table can be adopted, summarizing key information per each step and providing cells per each STRIDE category where a subject matter expert is expected to enter an evaluation of applicability. In case of an Information Asset, it can be relevant to mention (1) the source SA and its domain (for trust considerations), (2) the destination SA and its domain, (3) the PA subject to transfer, storage, or processing and the expected security properties, (4) details on the flow and possible presence of a trust boundary, and (5) details of SA in charge of transfer, storage, or processing (such as the communication protocol). Considering all of this information, it is possible to give an accurate evaluation of each STRIDE threat. As an example, some threats may be not applicable due to the security properties of the specific Primary asset (if confidentiality is not required, information disclosure threats may be disregarded), or knowledge of the communication protocol and other details of the SA may provide information on existing security measures against specific threats (encryption would protect against information disclosure threats). The analysis of the table produced by applying “per-Interaction” Threat Elicitation supports the identification of relevant threats, by their impact on Primary Asset Security Properties.

With the proposed approach, a focus lays on threats that apply at cross-stakeholder boundaries. In particular, if trust in a service or related information cannot be established, an information flow supporting the service or information transfer is subject to potential threats. The information flow can help in determining where the threats apply, how the potential compromise may be originated, and how it propagates. Consequently, it supports the identification of potential stakeholders involved in the mitigation strategy. For example, mitigation may require strengthening of the security posture of equipment in change of establishing cross-stakeholder communications channels, bridging uneven trust levels between stakeholders by dynamic evidence of integrity, authentication of data traversing untrusted domains, or the establishment of secure channels to bridge different trust domains. An application of a mitigation to one or more components causes the identification of a set of security requirements that the components are expected to satisfy.

Some mitigation decisions may resort on applying best practices to the target scenario. For this reason, it is frequent to adopt catalogues of mitigation (see also SecRAM catalogues [4], [11]), with the intent of fostering adoption of best practices across an heterogeneous ecosystem. The proposed framework defines mitigation solutions that may result in catalogue entries. Intending to introduce Zero Trust protection principles in the CNS ecosystem, the framework provides a Zero Trust Reference architecture and some embodiments in terms of applicable templates. As part of the joint mitigation activity, stakeholders may decide to adopt the

Zero Trust approach, which defines additional components or security capabilities to be added to the current architecture. An application of the Zero Trust approach causes, as any other mitigation, the definition of a number of security requirements.

As part of the mitigation actions, specific equipment may be assigned with a Security Profile, which may be reused from a recognized catalogue of profiles or may be defined as new to aggregate a specific set of security requirements emerged in the mitigation phase. The assignment of a Security Profile to an equipment will need to be reflected in the Threat Model by adding the Security Profile identifier label to the corresponding entity. In addition, Security Profiles can affect existing trust boundaries in the DFD by (1) causing the removal of the boundary because trust is ensured by compliance to the newly applied profile, or (2) causing the addition of a condition to a trust boundary that clarifies the dependency from the presence of the profile.

E. Slicing and harmonization

Slicing and harmonization address the need to interface Global Threat Modeling and Local Security Activities. To ensure coordination with other stakeholders, every stakeholder is expected to comply with his portion (Slice) of the Joint Threat Model and related Security Requirements.

Slicing formally supports the definition of the domain of responsibility of a single stakeholder in the Joint Threat Model. It encompasses extracting a portion of the Threat Model precisely including the entities under responsibility of the given stakeholder and the related data flows (starting or ending at included entities). In addition, the slice includes the flows that traverse the boundaries of responsibility of the given stakeholder and the entities that are at the other end of those flows. Those are external entities and are transformed into Input/Output entities of the stakeholder's slice. Every included flow maintains existing trust boundaries as in the Global Threat Model. All other entities and flows are not included in the slice. Slicing also includes Security Profiles and security requirements defined in the Global Threat Model.

The Threat Model slices obtained in this way are provided as input to the corresponding stakeholders for their own security process and in compliance with applicable sector-specific regulation. Note that Local Threat Modeling may be performed based on a Local Threat Catalogue considering threats that are specific for the selected scope and with adequate detail for the involved technologies. No need of harmonization and coordination between Local Threat Catalogues is envisioned, because the coordination is performed through the Global Threat Model and using the corresponding (common) Threat Catalogue.

Local Threat Modeling may identify additional information flows crossing the domain of responsibility of the single stakeholder to reach other stakeholders. To keep consistency with the Joint Threat Model and ensure awareness of other stakeholders, such additional information is propagated from the Local Threat Modeling to the Global Threat Modeling for Harmonization. Changes to the Joint Threat Model due

to Harmonization or Mitigation may trigger the elicitation of additional threats and definition of additional mitigation actions.

IV. REFERENCE ZERO TRUST ARCHITECTURE

A. Objectives of the architecture

The ever-evolving threat landscape requires architectures with a high-level of resilience, moving from a perimeter-based defenses to a defense-in-depth model with enhanced threat detection and containment. With each component participating to the overall security posture, such architectures provide multiple layers of defense along threat paths. Improved threat detection capabilities allow to detect threats earlier and enable reconfigurations of security controls to avoid a threat propagation to critical resources.

Nevertheless, challenges of implicit trust remain: after authentication, trust on an entity is kept indefinitely, independently from the security context, until the end of a session. Such implicit trust should be avoided in favor of continuous checks on the security of the connecting entities. With "never trust, always verify" as the guiding motto, the key principles behind Zero Trust according by NIST [3] are to verify explicitly, apply least privileges, assume breaches, ensure secure access to all resources, monitor and inspect all traffic, enforce dynamic and context-aware policies, and use a Zero Trust mindset across the organization.

B. Reference architecture

Figure 5 illustrates a Reference Zero Trust Architecture composed of the following key elements:

- Policy Decision Point: composed by the Policy Administrator and Policy Engine which are the core components implementing the capability of continuous trust evaluation and communication path establishment/blocking in a Zero Trust architecture.
- Policy Enforcement Point: Enforces access control policies. It regulates and monitors access to resources by evaluating and applying predefined rules, ensuring compliance with security policies.
- Policy Information Point: Attempts to acquire information required by the policy to execute from by Information Providers
- Entities and Security Profiles: Elements which need to exchange data between each others and where each entity has an associated security profile describing its security properties.
- Policy Decision Data sources: external information databases that can provide contextual information needed by policies.

The definition of a Joint Mitigation Plan, as a consequence of the Collaborative Threat Modeling process, directs the configuration of those Zero Trust elements to meet the desired Security Objectives, providing the following benefits:

- Enhanced security: continuous verification of identities, checking of access rights against security policies

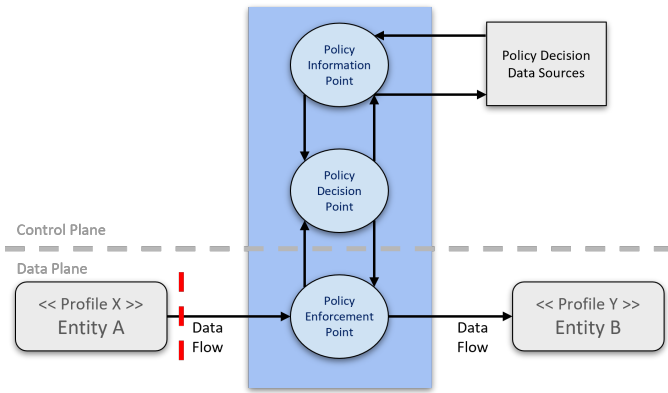


Fig. 5: Reference Zero Trust Architecture

- Improved visibility and control/reactivity: security monitoring and reaction upon detection by enforcement of security policies
- Enabler for smaller trust areas: smaller zones grouping systems by criticality
- Enabler for reconfiguration capabilities: react upon a detection and adapt security controls for threat containment

Two examples of instantiations of the notional Zero Trust Architecture are provided below. The first is focused on the airborne domain, while the second in Section V considers an air-to-ground architecture.

C. Zero Trust for airborne communication

Figure 6 shows a nominal exchange of information between two airborne systems where some data coming from outside of the *Aircraft Control Domain* is being checked and eventually sanitized by a security gateway at the border of the domain and then routed to the target system. This is a traditional perimeter-based security architecture where, once verified, the source entity is trusted for all following data exchanges often based on the source address.

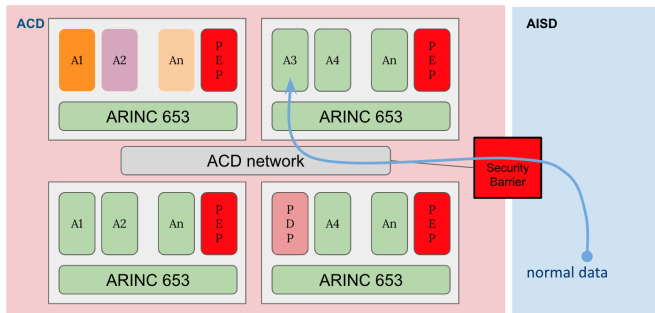


Fig. 6: Onboard communications, nominal situation

In contrast to a perimeter-based protection model, Figure 7 represents a Zero Trust approach where the source entity is being checked at each exchange and, upon detection of abnormal data, the border Policy Enforcement Point (PEP) redirects the traffic to an intermediate security application

(another PEP) hosted as partition responsible for more granular filtering or rejection of data in relation of the criticality of the target system.

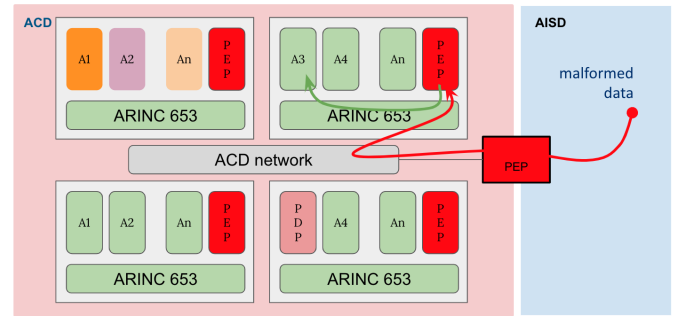


Fig. 7: Onboard communications, anomaly detected and traffic redirected

D. Challenges in the application of Zero Trust

One of the major benefits of Zero Trust architectures is the capability to timely reconfigure security controls for threat containment. Implementing such capabilities on aircraft, however, is a challenge, especially when dealing with safety-critical avionics that need to meet performance requirements for safety. Even if technologies are available to enable full dynamic reconfiguration of security controls, safety shall always drive the definition of security policies. Defining a set of tested and verified configurations with well-defined transition scenarios promises to support meeting performance requirements in case of a detected threat. Work in this direction is being performed in the context of the FCDI project to define possible approaches to address safety considerations.

V. VALIDATION ON HYPER-CONNECTED ATM CONCEPT

The Hyper-Connected ATM (HCATM) concept [1], [12] has been defined to address congestion of Air Traffic Control (ATC) and Airline Operations (AOC) data-link communications by leveraging available non-safety data-link technology (such as, 4/5G at airport, Ka/Ku band SATCOM, and future technologies) as complementary communication channels to improve the capacity of safety datalink communication.

The HCATM architecture, as shown in Fig. 8, is realized by the introduction of airborne and ground HCATM gateways in charge of establishing an end-to-end communication tunnel through commercial networks for routing communications otherwise transferred via safety links. The HCATM concept is under development in the context of the ongoing SESAR FCDI project [13].

The current section provides a brief overview on the validation of the Collaborative Cybersecurity Framework for CNS exemplarily applied to the HCATM scenario. For illustration purposes, the Shared Security Objectives address the protection of (1) ATS messages against threats to integrity and availability, and (2) AOC messages against threats primarily to confidentiality.

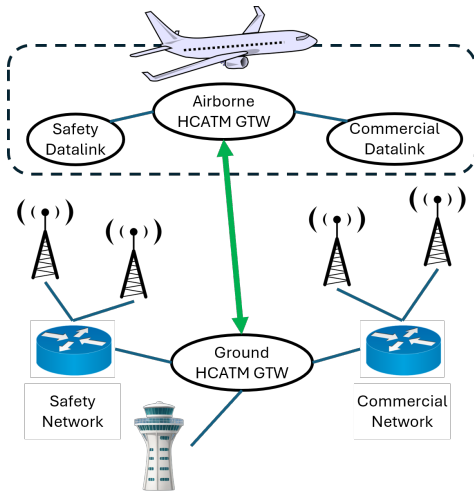


Fig. 8: HCATM use case from the SESAR FCDI project

Figure 9 shows one of the DFD produced to define the Joint Threat Model and used to perform STRIDE-driven threat elicitation. In the model, stakeholders have identified several trust boundaries that, as explained in Section III, represent untrusted interactions. In particular, every flow traversing boundaries at a different level of security (and therefore trust) are labeled with a trust boundary. Examples are interactions between public networks and safety-critical ground service providers, interactions between AOC/ANSP and Communication Service Providers (CSPs), interactions between ground and aircraft, and interactions between aircraft domains of different criticality.

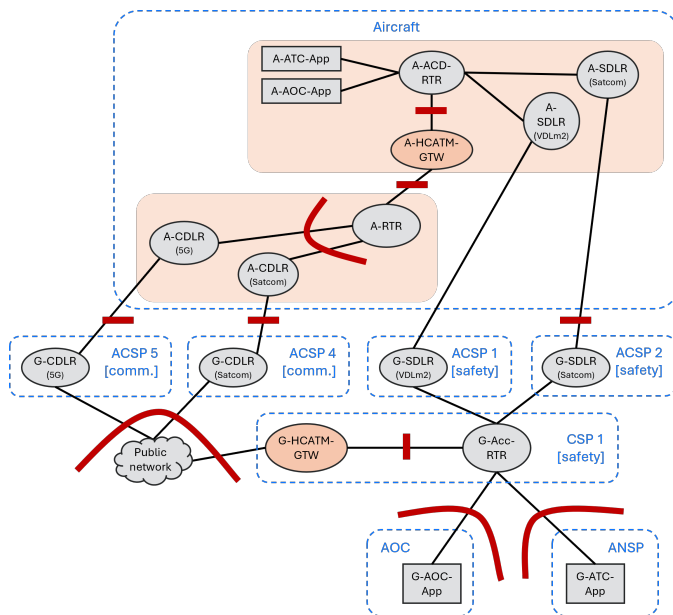


Fig. 9: DFD representing one possible HCATM architecture view

The trust model can be further refined in terms of its Trust Boundaries. Figure 10 provides an example: trust between the

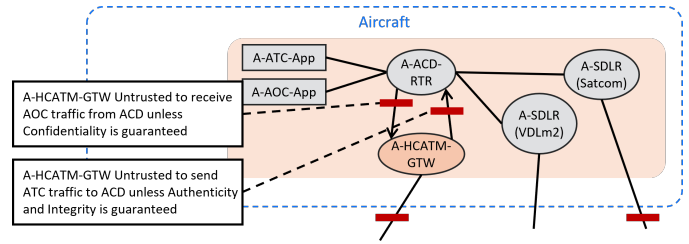


Fig. 10: HCATM Trust Boundary conditions depending on assets

Airborne Aircraft Control Domain (ACD) Router (A-ACD-RTR) and the Airborne HCATM Gateway (A-HCATM-GW) can be subject to conditions, depending on the asset that are considered. In this example, the boundaries specify how the A-HCATM-GW shall only be trusted to receive AOC data if protected from a confidentiality perspective, while on the other side, the A-ACD-RTR shall trust data coming from the A-HCATM-GW only if strong authenticity and integrity guarantees are provided. Notice that the same conditions are modeled also on the ground HCATM gateway trust boundaries since the two systems carry the same responsibilities. Such an example illustrates how fine-grained trust relations can be modeled with the support of Trust Boundary conditions.

The threat elicitation process identifies a number of possible threats that might violate the established Shared Security Objectives. One of the relevant threats identified in the elicitation process concerns compromising the secure tunnel created through the commercial network by the Air/Ground HCATM gateways. Figure 11 represents an exchange of information through a tunnel established upon mutual authentication with a ground gateway. Once the tunnel is established, a trust relation is established till the end of the tunnel. This is a traditional approach, based on security perimeters. However, HCATM gateways are exposed towards untrusted networks and may be subject to attacks affecting their integrity. An attacker taking control of the ground segment could be able to propagate inside the tunnel up to the target system. Therefore, trust granted cannot only depend on the secure tunnel itself but should also depend on the tunnel endpoints integrity. For a transition towards Zero Trust principles, integrity should not be assumed, but explicitly identified as a prerequisite and verified before any connection is allowed.

After threat elicitation, stakeholders proceed with the identification of a Joint Mitigation Plan. In the HCATM use case, mitigation of the identified threats leads to the definition of a number of security requirements. Their applicability depends upon the specific asset that is being transferred. As mentioned, ATS data requires integrity and availability guarantees, while AOC data requires primarily confidentiality. Stakeholders may decide to define Security Profiles addressing those requirements, to facilitate standardization, harmonize HCATM gateway equipment security, and ensure interoperability for security operations.

Table III provides some exemplary Security Profiles for

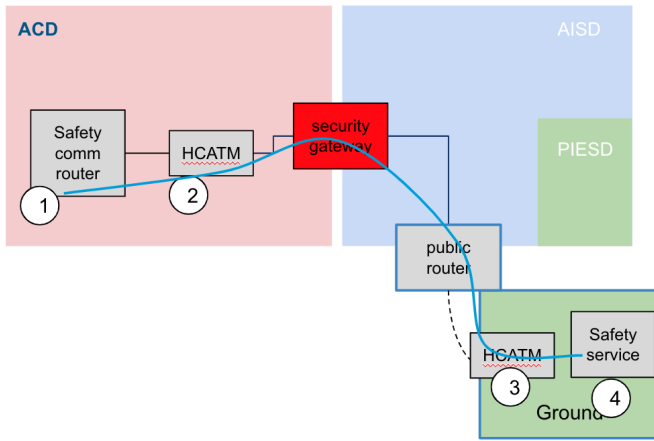


Fig. 11: HCATM concept with traditional, perimeter-based security

HCATM gateway equipment. Profile SP-G1 describes capabilities that shall be satisfied by a standard Secure Gateway, with basic security due diligence, support for establishing secure remote authentication and tunneling, and network protection from malicious packets by means of content-based filtering. Profile SP-G2 can be considered an evolution in terms of security level, by adding the capability of checking integrity of the gateway before using any of its services (including the secure tunneling service). Clearly, the two Security Profiles are adequate for different purposes: SP-G1 can be trusted for routing AOC data, while safety-critical ATS data may demand the security properties offered by SP-G2. As usual for any aspect subject to standardization, the definition of Security Profiles requires an agreement from all the involved stakeholders, since they are going to be responsible for compliance to the specified profile.

Profile ID	Profile Name	Implemented Functional Security
SP-G1	HCATM GTW Profile 1	Basic security functions for a Secure Gateway, Secure tunneled connection, Network packet filtering
SP-G2	HCATM GTW Profile 2	SP-G1 + Integrity assurance of GTW

TABLE III: HCATM Gateway Security Profiles

As part of the Joint Mitigation Plan, entities in the DFD are labeled with Security Profiles, mitigating identified threats and, possibly, causing the removal or modification of Trust Boundaries. Specifically, HCATM gateways can expose different Security Profiles. Besides these purely static aspects of threat mitigation, there are also dynamic aspects realized by Zero Trust decision/enforcement points. Based on the different security guarantees provided by each gateway, AOC/ATS

traffic may or may not be authorized. Authorization may be dynamic, depending on the specific Security Profile of the ground gateway to which the aircraft is currently connected. The aircraft can take advantage of non-safety communication datalinks for different AOC/ATS traffic routing configurations based on the provided security guarantees.

Table IV shows exemplary HCATM policies. Assuming the system supports two different data flows named AOC and ATS with different sensitivity level, notice how safety-critical ATS information can only be transmitted through the HCATM tunnel if both the ground and airborne gateways are equipped with the SP-G2 security profile while the AOC data can be shared through the HCATM link if the system is composed by two gateways that both have at least a basic security profile. Finally, if one of the two gateways does not even satisfy the basic security profile requirements, no data transfer can be enabled through the tunnel.

Security Profile		Allowed Flows	
A-HCATM-GTW	G-HCATM-GTW	AOC	ATS
N/A	*	N	N
*	N/A	N	N
SP-G1	SP-G1 or SP-G2	Y	N
SP-G1 or SP-G2	SP-G1	Y	N
SP-G2	SP-G2	Y	Y

TABLE IV: Security Policies based on the Security Profiles

The profile SP-G2 (on guaranteeing integrity of the gateway for the entire duration of the secure connection) can, for example, be satisfied by relying on *Remote Attestation* [14]. Figure 12 represents a reusable template that illustrates how Remote Attestation can be integrated in compliance with the Zero Trust Reference Architecture discussed in Sec. IV. This architecture template addresses the need for assessing integrity of an endpoint before authorizing the establishment of a secure connection between stakeholders. It relies on a trusted verifier acting as a root of trust for validation of integrity measurements collected from the target endpoint. The validated information is used by the policy decision point to direct the policy enforcement point to authorize or deny connectivity, based on the validated information.

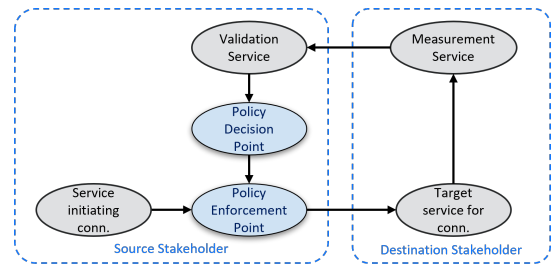


Fig. 12: Remote Attestation pattern.

Fig. 13 illustrates a Zero Trust enabled HCATM architecture. Upon request of a ground connection (1ZT), before secure channel establishment and at every data exchange, the airborne HCATM gateway (2ZT) requires an authorization from the PEP (3ZT) for the network interaction. The PEP

receives the authorization decision from the PDP on the basis of the result of measurement and onboard verification (4ZT). Upon authorization, a secure channel can be established with the ground HCATM gateway (6ZT) and safety-critical communication with ground is possible (7ZT). The onboard Trust Verifier would continuously check security properties of the ground segment and inform the Policy Decision Point (PDP) about any change in the security state. As soon as the expected security properties of the ground segment are not matching anymore expected ones, the PDP will instruct the PEP to close the tunnel.

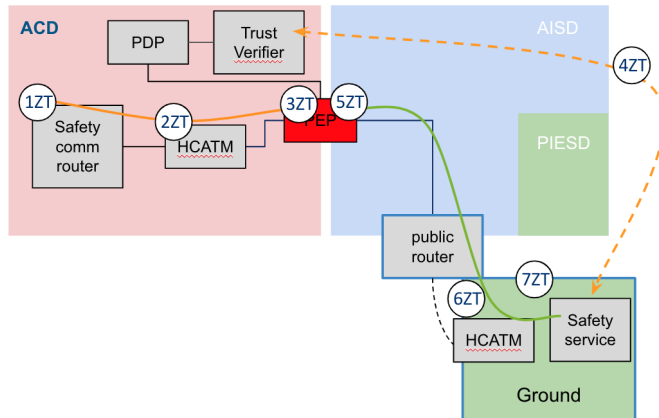


Fig. 13: HCATM concept with a Zero trust based architecture

As part of the ongoing validation in the FCDI project, a prototype implementation of the architecture described in Fig. 13 has been developed. The ground HCATM gateway is designed to comply with a SP-G2 security profile. Details of implementation of the remote attestation zero-trust architectural template in the context of the HCATM architecture are provided separately [15].

At the conclusion of the Joint Threat Mitigation activity, the Joint Threat Model is updated to represent the agreed upon mitigation actions, including modifications of the Trust Boundaries, application of Security Profiles, and integration of new entities introduced by the application of a Zero Trust template architecture. The final artifact is a documentation of the trust agreements established between stakeholders to guarantee end-to-end protection of Primary Assets. It establishes the grounds for collaboration around cybersecurity objectives and clarifies the responsibilities of each stakeholder.

The FCDI project implementation and validation activity is still ongoing and the evaluation objectives are not achieved completely yet. As part of on-going work, changes due to joint mitigation (including the integration of the Zero Trust architectural components, such as the Validation Service) caused modifications to the Joint Threat Model that require a revision of the Threat Elicitation results as well as (potentially) of the Joint Mitigation Plan.

VI. NEXT STEPS

As next steps, there are several directions to pursue covering research as well as technical development. First, alignment with existing cybersecurity regulations and sectorial practices should continue to facilitate an adoption and improve usability. Some work has already been performed in this direction to ensure alignment with major processes and methods already in place for the ground and airborne side of the ecosystem. For example, a preliminary alignment with SecRAM has been shown while interfacing as well as exchanged artifacts deserve further clarifications, possibly with applied examples in the context of CNS applications. The framework may be of particular interest for CNS standardization activities. As such, dissemination to standard-making organization has been initiated and is planned to be continued.

Second, the completion of the validation exercises in the context of the FCDI project are essential to confirm the viability, perform adjustments, and refine artifacts produced in each step as well as support improvements for better usability and value proposition.

Third, the role of Zero Trust as a systematic approach for joint mitigation requires further clarification. Zero Trust principles and recurrent architectures can be formalized in terms of architectural patterns, an area that is already under exploration in the context of the FCDI project. In addition, Security Profiles play a crucial role for harmonization of trust and fostering of collaboration, so it would be important to better formalize their use and provide an extended set of example scenarios. Likewise, Security Profiles, among other concepts, are good candidates for being part of a future CNS end-to-end security standard or guideline.

Fourth, looking at the more dynamical aspects of cybersecurity management, the role of the Zero Trust Reference Architecture to facilitate security interoperability and coordinated response, in cases of detected threats during operations, deserves further exploration. This should include considerations how the framework can further support security operations, e.g., for sharing threat intelligence among stakeholders or supporting more accurate and efficient incident management. Similarly, safety aspects in the definition of Zero Trust solutions require further exploration. Due to the inherent complexity of the problem, considering compliance of Zero Trust policies with cascading safety requirements can benefit from a modeling approach that can support improved consistency by application of tools for threats and impacts analysis. Combinations of multiple threats and safety effects are complex to assess and are also being addressed, in terms of problem formulation, by existing standardization working groups on cybersecurity for civil aviation.

REFERENCES

- [1] EU/US Task Force, "Future connectivity for aviation," EASA, FAA, Airbus, Boeing, Tech. Rep., 2022. [Online]. Available: <https://www.easa.europa.eu/en/document-library/general-publications/future-connectivity-aviation>

- [2] FCDI SESAR Project, "Presenting HCATM," https://www.linkedin.com/posts/fcdi-future-connectivity-and-digital-infrastructure_fcdi-atm-vdl-activity-7184473801689055232-imzd, 2024, [Online; accessed 2-February-2025].
- [3] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST, Tech. Rep. SP 800-207, 2020.
- [4] M. le Fevre, B. Götz, R. Flohr, T. Stelkens-Kobsch, and T. Verhoogt, "Secram 2.0 – security risk assessment methodology for sesar 2020," SESAR JU, Tech. Rep. 02.00.00, 2017.
- [5] Adam Shostack, *Threat Modeling: Designing for Security*. Wiley, 2014.
- [6] GPS Spoofing WorkGroup, "GPS spoofing final report," OPSGROUP, Tech. Rep., 2024. [Online]. Available: <https://ops.group/blog/gps-spoofing-final-report/>
- [7] EUROCAE WG-72 and RTCA SC-216, *Airworthiness Security Process Specification*. EUROCAE, 2024, no. ED-202B.
- [8] —, *Airworthiness Security Methods and Considerations*. EUROCAE, 2018, no. ED-203A.
- [9] —, *Process Standard for Security Certification and Declaration of ATM/ANS Ground Systems*. EUROCAE, 2022, no. ED-205A.
- [10] Common Criteria, "Common Criteria for Information Technology Security Evaluation," Common Criteria, Tech. Rep., 2022. [Online]. Available: <http://www.commoncriteriaportal.org/>
- [11] D. Martintoni, V. Senni, G. S. Gaba, and A. Gurtov, "On the role of SecRAM catalogues in ATM cyber risk assessment and improvement opportunities," in *2025 Integrated Communications, Navigation and Surveillance Conference (ICNS)*, to appear.
- [12] SESAR JU, "PJ.14-W2-61 SESAR Hyper Connected ATM solution," <https://www.sesarju.eu/sesar-solutions/hyper-connected-atm>, [Online; accessed 7-February-2025].
- [13] —, "FCDI Project Webpage," <https://www.sesarju.eu/projects/FCDI>, 2024, [Online; accessed 2-February-2025].
- [14] H. Birkholz, D. Thaler, M. Richardson, N. Smith, and W. Pan, "RFC 9334 Remote Attestation procedureS (RATS) Architecture," IETF, Tech. Rep., 2023. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc9334>
- [15] D. Martintoni, V. Senni, and L. Leonardon, "Remote attestation for high assurance ATM communications through commercial network," in *2025 Integrated Communications, Navigation and Surveillance Conference (ICNS)*, to appear.